

Noah Frost

📍 Newcastle upon Tyne ✉ REDACTED ☎ REDACTED 🔗 [linkedin.com/in/nfroze](https://www.linkedin.com/in/nfroze) 🐙 github.com/nfroze
🔗 noahfrost.co.uk

DevSecOps engineer with 20+ infrastructure and security projects, an autonomous AI build system, and a self-hosted Kubernetes cluster with live observability. Projects span zero trust architecture, software supply chain security, secrets management, AI security testing, and full DevSecOps pipelines - all with Terraform IaC, production security hardening, and documented architecture decisions. Trained under a Global CISO in DevSecOps methodology. Background in policing brings proven stakeholder communication, compliance mindset, and decision-making under pressure. AWS, Security+, and Terraform certified.

Technical Skills

- Cloud & Infrastructure: AWS (EKS, ECS, EC2, Lambda, GuardDuty, Security Hub, IAM, KMS), Azure, GCP, Terraform, CloudFormation, K3s
- Container Orchestration: Kubernetes, Docker, EKS, K3s, ArgoCD, Helm, Kyverno
- CI/CD & Automation: GitHub Actions, GitLab CI, Jenkins, GitOps workflows
- Security Tools: Checkov, Trivy, Semgrep, Gitleaks, OPA Gatekeeper, Sentinel, Splunk SIEM, OWASP ZAP, Syft, cosign/Sigstore, Grype
- Zero Trust & Network Security: Cilium (eBPF), SPIFFE/SPIRE, WireGuard, Hubble, Cloudflare Tunnel, Network Policies, RBAC, Pod Security Standards
- Observability: Prometheus, Grafana, kube-state-metrics, node-exporter, ELK Stack, OpenTelemetry, Fluentd
- Languages & Scripting: Python, Bash, Node.js, YAML, HCL
- Secrets Management: HashiCorp Vault (HA/Raft, dynamic secrets, Transit, PKI), Vault Secrets Operator, AWS KMS

Homelab - AI Build System & Kubernetes Cluster

Phase 1: Autonomous Webapp Pipeline

Designed and built an end-to-end autonomous build system (Jarvis) running on a dedicated Mac with its own GitHub account, AWS credentials, and deployment pipeline. The system takes a webapp brief and delivers a live, deployed application - hero art generation from a self-trained LoRA model, animation, build spec, autonomous code generation, and AWS deployment - with zero manual intervention.

- Architected agent workflow integrating OpenClaw, Claude Code, GitHub CLI, AWS, and Cloudflare into a single checkpointed pipeline
- Five production security webapps built and deployed through this system: vulnerability intelligence (NVD/CISA KEV/EPSS fusion), OWASP LLM security assessment, dependency risk analysis with CycloneDX SBOM export, AI regulatory compliance mapping (EU AI Act, UK GDPR, NIST AI RMF, and 3 more), and AWS CIS Benchmark posture scanning
- All five webapps live and running on AWS for under \$3/month combined

Hub site: <http://nfroze.co.uk> GitHub: <https://github.com/NFrozeCLAWDBOT>

Phase 2: Kubernetes Cluster & AI Operations

Provisioned a K3s cluster on the same Mac running Jarvis, hardened it to production security standards, deployed full observability, and published a self-hosted build log - served by the cluster it documents.

- K3s on Apple Silicon with Cloudflare Tunnel (zero inbound ports, no public IP, outbound-only QUIC connection)
- Security hardening: 4 namespaces with Pod Security Standards enforcement, 12 network policies (default deny), RBAC with scoped service accounts, non-root pods (UID 101), read-only rootfs, all capabilities dropped
- kube-prometheus-stack: Prometheus, Grafana (28 dashboards, publicly accessible), node-exporter, kube-state-metrics
- Jarvis queries cluster health via kubectl in real time - AI operator managing live infrastructure, not just building it

Live: <https://k3s.nfroze.co.uk/> Dashboard: <https://dashboard.nfroze.co.uk/>

Projects

Zero Trust Kubernetes Architecture | [GitHub]

Production-grade zero trust on EKS using Cilium eBPF - aligned to NIST SP 800-207

- Implemented Cilium kube-proxy replacement with SPIFFE/SPIRE workload identity, mTLS service mesh, and WireGuard node-to-node encryption
- Enforced L7 micro-segmentation controlling HTTP methods and URL paths per service across three security zones (public/private/restricted)
- Deployed Hubble for L7 flow observability and policy verdict logging with Prometheus/Grafana dashboards
- Five microservices with default-deny baseline, non-root containers, read-only filesystems, and CI validation across Terraform, manifests, containers, and Dockerfiles

Supply Chain Security Pipeline | [GitHub]

End-to-end software supply chain security with SBOM, signing, provenance, and admission control on EKS

- Generated dual-format SBOMs (SPDX + CycloneDX) via Syft meeting CISA minimum elements requirements
- Implemented keyless signing via cosign/Sigstore with GitHub OIDC federation - signing identity tied to CI, recorded in Rekor transparency log
- Built SLSA Level 2 provenance attestation and Gype vulnerability scanning at both build and deploy stages
- Deployed 5 Kyverno ClusterPolicies in Enforce mode: signature verification, provenance validation, SBOM attestation, registry restriction, and container hardening

Secrets Management with HashiCorp Vault | [GitHub]

Centralised dynamic secrets platform replacing static credentials across databases, cloud IAM, TLS, and encryption

- Deployed Vault 1.15.4 in HA mode on EKS with Raft consensus, 3 replicas across AZs, and AWS KMS auto-unseal via IRSA
- Configured 4 secrets engines: dynamic PostgreSQL credentials per instance, dynamic AWS IAM users, Vault-issued TLS certificates (PKI), and encryption-as-a-service (Transit)
- Implemented Vault Secrets Operator syncing secrets to Kubernetes via CRDs - no Vault SDK dependency in application code
- Built Prometheus alerting for seal status, leader health, and quorum loss with NetworkPolicy enforcement

Agentic AI Security Testing | [GitHub]

Automated security testing platform probing AI agents against OWASP Top 10 for LLMs (2025) and Agentic AI (2026)

- Built plugin-style attack registry with auto-discovery decorators - extensible without modifying orchestration code
- Implemented composite scoring combining pattern matching, canary detection, and confidence thresholds to reduce false positives
- Deployed on ECS Fargate with dual CI/CD pipelines (21 jobs): CI pipeline (lint, test, build, scan) and security pipeline (Bandit, CodeQL, Semgrep, Checkov, Docker Bench)
- 17 custom Semgrep rules, multi-stage Docker builds, non-root containers, read-only rootfs, VPC endpoints for ECR/Secrets Manager/S3/CloudWatch

End-to-End DevSecOps Transformation | [GitHub]

Production-grade security pipeline embedding scanning at every stage from code commit through runtime monitoring with Splunk Cloud SIEM

- Built gated workflow chain: 4 chained GitHub Actions workflows where failed security scans block progression before container build
- Integrated Semgrep SAST, Trivy SCA, Gitleaks secrets detection, Checkov IaC scanning, and OWASP ZAP DAST with security gates blocking non-compliant code
- Deployed to EKS with GuardDuty, Security Hub, CloudTrail, and VPC Flow Logs streaming to Splunk Cloud via dual ingestion (AWS Add-on pull + OTel Collector push)
- Hardened container defaults: npm/corepack removed at build, UID 10001, read-only rootfs, all capabilities dropped, seccomp enforced

AI/ML Governance with Policy-as-Code | [GitHub]

Dual-layer policy enforcement preventing non-compliant infrastructure and untracked ML models reaching production

- Developed 4 Sentinel policies for HCP Terraform blocking GPU instance provisioning and enforcing AI resource tagging pre-apply
- Built OPA Gatekeeper admission webhooks requiring ML tracking labels and model registry URLs on Kubernetes deployments
- Mapped controls to EU AI Act compliance requirements with risk-level tagging and per-team budget caps

Healthcare STRIDE Threat Model | [GitHub]

Comprehensive threat model for HIPAA-compliant healthcare platform handling PHI and PII

- Identified 15 prioritised threats across authentication, data protection, API security, and infrastructure using STRIDE methodology
- Mapped threats to MITRE ATT&CK framework and HIPAA Security Rule requirements (§164.308–312)
- Produced remediation guidance with working code examples bridging security architects and developers

Additional Projects: <https://github.com/nfroze>

- GitOps Pipeline with ArgoCD | EKS + ArgoCD auto-sync/self-healing + Prometheus/Grafana
- Kubernetes Observability Stack | ELK + Fluentd + Prometheus on EKS
- AI FinOps Platform | Strimzi Kafka streaming GPU/API costs with OpenCost
- AI/ML Developer Platform | Backstage + MLflow + ArgoCD on hybrid EKS/ECS
- CI/CD Pipeline Comparison | Jenkins vs GitLab CI on shared AWS infrastructure
- Multi-Cloud Orchestration | AWS + Azure + GCP from single workflow with Ansible/Datadog
- 3-Tier Serverless Application | React + Lambda + DynamoDB + CloudFront with modular Terraform
- Portfolio CI/CD Pipeline | S3 + CloudFront + Route 53 with automated cache invalidation

Certifications

- CompTIA Security+
- AWS Certified Cloud Practitioner
- HashiCorp Certified: Terraform Associate
- AWS Certified Solutions Architect – Associate — IN PROGRESS

Training

- DevSecOps Bootcamp, Led by Charlie Banyard, Global CISO09/2024 – 11/2024 | Remote
- Security integration across software development lifecycle
- Cloud security architecture and threat detection
- Compliance automation and policy-as-code

Professional Experience

- Police Constable, Metropolitan Police02/2022 – 09/2023 | London, UK
- Frontline officer responsible for incident response, evidence management, and multi-agency coordination
- Translated complex legal and procedural requirements for non-expert audiences including courts, social services, and public stakeholders
- Made time-critical decisions under pressure with incomplete information during active incidents
- Wrote detailed reports meeting evidential standards for criminal prosecution
- Coordinated with multiple agencies ensuring compliance with data protection and governance requirements

Education

- Law (Criminal Justice) LLM, Northumbria University09/2023 – 2024
- Criminology BSc (Hons), University of Chester09/2016 – 09/2020